

Task 9 — Vuln-Bank Vulnerability Assessment

Objective

Perform a local security assessment of Vuln-Bank deployed via Docker Compose and report key findings and remediation recommendations.

Setup

Commands executed (examples):

```
git clone https://github.com/Commando-X/vuln-bank.git
cd vuln-bank
docker-compose up --build -d
```

Target URL: `http://localhost:PORT`

Tools used

nmap, nikto, Burp Suite, sqlmap, curl, jq

During testing I exploited an SQL injection vulnerability in POST `/login` to achieve authentication bypass, escalate to an administrative account, approve a pending loan, and verify the loan status from the original user — this is a critical flaw requiring immediate remediation.

Finding header

- **Finding — Authentication Bypass via SQL Injection — Critical**

Concise description (2 lines)

- The login endpoint concatenates user input into SQL queries without parameterization, allowing crafted input to alter authentication logic and grant administrative access.
- Using the admin session I approved a pending loan submitted earlier by a regular user; the loan status was reflected in the user's account.

Reproduction steps (compact, numbered)

1. Log in as a regular user and submit a loan request; note the loan id .
2. POST a crafted payload to `/login` to obtain an admin session cookie.
3. Use the admin session to approve the pending loan (POST `/admin/loans/approve` with `loan_id=1234`).
4. Re-login as the original user and confirm the loan status is **Approved**.

Impact statement

- Critical: allows account takeover and unauthorized privilege escalation enabling fraudulent actions (e.g., approving loans) with direct financial and reputational impact.
- An attacker exploiting this could fully compromise application integrity and perform business-critical transactions.

Root cause

Root cause: unsanitized/concatenated SQL in the authentication logic (no prepared statements / parameterized queries).

Remediation

Immediately replace all dynamic SQL with parameterized queries / prepared statements for authentication and

all DB interactions.

Enforce server-side authorization checks on all admin-sensitive endpoints and log all privileged actions.

Rotate session secrets/credentials if there is suspicion of exploitation during testing; add MFA for admin accounts.

```
File Actions Edit View Help
Command 'docker-compose' not found, but can be installed with:
sudo apt install docker-compose
Do you want to install it? (Y/n)
sudo apt install docker-compose
The following packages were automatically installed and are no longer required:
  python3-packaging-whl python3-pyinstaller-hooks-contrib python3-wheel-whl
Use 'sudo apt autoremove' to remove them.

Installing:
  docker-compose

Installing dependencies:
  docker-buildx docker-cli

Suggested packages:
  docker-doc

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 0
  Download size: 7,3k; kB / 33.5 MB
  Space needed: 101 MB / 32.8 GB available

Continue? [Y/n] Y
Err:1 http://http.kali.org/kali kali-polling/main amd64 docker-cli amd64 26.1.5dfc9f1-9+37
404 Not Found [IP: 54.39.128.230 80]
E: Failed to fetch http://http.kali.org/kali/pool/main/d/docker.io/docker-cli_26.1.5dfc9f1-9+37_amd64.deb 404 Not Found [IP: 54.39.128.230 80]
E: Unable to fetch some archives, maybe run apt-get update or try with --fix-missing
Command 'docker-compose' not found, but can be installed with:
sudo apt install docker-compose
Do you want to install it? (Y/n)
sudo apt install docker-compose
The following packages were automatically installed and are no longer required:
  python3-packaging-whl python3-pyinstaller-hooks-contrib python3-wheel-whl
Use 'sudo apt autoremove' to remove them.

Installing:
  docker-compose

Installing dependencies:
  docker-buildx docker-cli

Suggested packages:
  docker-doc

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 0
  Download size: 7,3k; kB / 33.5 MB
  Space needed: 101 MB / 32.8 GB available

Continue? [Y/n] Y
Err:1 http://http.kali.org/kali kali-polling/main amd64 docker-cli amd64 26.1.5dfc9f1-9+37
404 Not Found [IP: 54.39.128.230 80]
```

